CancerOS AI Safety Privacy and Scientific Integrity

Document ID: COS-SPEC-010

Version: 1.0

Date: 22 October 2026

Status: Proposed mandatory controls for the research prototype

1 Purpose and authority

CancerOS shall preserve authentic research observations, identify every simulated or estimated result, protect source data and restrict statements to what available evidence supports. This specification governs ingestion, processing, simulation, inference, visualization, exports and the final presentation. A research-only disclaimer supplements technical controls; it does not make unsupported clinical output acceptable.

The scope is a breast cancer research proof of concept. It does not provide diagnosis, prescribing, treatment selection or validated individual prognosis. Controls here operationalize the architecture, database/API contracts and UI specification. They do not establish regulatory approval, legal compliance or clinical validity. Applicable obligations depend on actual sources, participants, jurisdictions, recipients and use; determine them before introducing additional sensitive data.

MUST and SHALL denote release requirements. Rules are identified for automated tests and review. The project owner is accountable for release, the data steward for source/privacy checks, the scientific reviewer for scientific claims, and the engineering owner for enforcement. One person may perform several functions during a hackathon; record that limitation. External clinical review should be sought for disputed medical interpretation; if unavailable, restrict output to source-supported descriptive statements rather than implying specialist approval.

2 Risk and control model

Maintain a versioned risk register recording hazard, trigger, affected person or asset, severity, control, test, owner, residual limitation and decision. NIST's voluntary AI risk resources provide general governance context [R1]; the controls and gates below are CancerOS project rules, not NIST certification requirements.

Hazard	Required control	Release response
Simulated data believed to be real	Canonical origin, branch isolation, persistent labels and export metadata	Block affected publication and presentation
Incorrect patient, date or lesion linkage	Composite ownership checks and reviewed source correspondence	Quarantine affected case
Invalid measurement or registration	Deterministic physical-space checks and source-mask inspection	Suppress unsupported measurement/overlay
LLM fabricates clinical conclusion	Bounded input, claim references, numeric checks and allowed output rules	Reject interpretation; keep valid source views
Privacy leak through source or inference	Minimized data, private storage, export policy and access checks	Stop affected access/export and investigate
Synthetic descendants inflate evaluation	Original-patient identity groups and partition lock	Withdraw invalid score and rerun
Demo misrepresents capability	Pinned evidence, honest saved/live labels and limitations	Correct script or omit unsupported claim

3 Canonical provenance rules

SAFE-01 Every source or result shall carry a canonical origin: REAL_OBSERVED, REAL_DERIVED, SYNTHETIC_GENERATED, INTERPOLATED or MODEL_PREDICTED, as defined by COS-SPEC-008. Availability, QC and publication are separate fields. Origin cannot be inferred solely from the patient-state context.

SAFE-02 REAL_DERIVED is reserved for documented computation from real input. A measurement or mesh computed from a synthetic mask remains SYNTHETIC_GENERATED, with its processing lineage retained. Mathematical processing cannot promote a hypothetical result to real evidence. Mixed-origin aggregates identify each contributing origin and branch; they must not be labeled wholly observed. This resolves the ambiguity in COS-SPEC-004's reference to derived synthetic measurements.

SAFE-03 The shared source baseline remains observed/real-derived inside a hypothetical branch. Every generated follow-up is branch-owned. No simulation, interpolation or prediction may fill an absent real laboratory result or create an authentic MRI examination. A within-examination DCE phase is never a genuine follow-up visit.

SAFE-04 Store source/release identity, protected patient linkage, original artifact hash, exact source locator, time basis, transformation code/configuration, parent resources and validation history. A checksum validates bytes, not identity, rights or medical truth. A valid source URL alone is insufficient lineage.

SAFE-05 Accepted source content and published snapshots are immutable. Corrections and retractions are appended. New source evidence can produce a new snapshot and a superseded-current-timeline indication; it does not rewrite an old snapshot or rebase a published synthetic branch silently.

SAFE-06 Original-patient identity groups govern deduplication and evaluation splits across collections, processed datasets, visits, crops, masks and synthetic descendants. Unknown cross-cohort linkage is not proof of independence. Hold unresolved duplicates out of independent-performance claims.

4 Synthetic disclosure across every surface

Surface	Minimum disclosure
Case and branch header	Hypothetical scenario plus family/run; actual baseline remains separately labeled
3D viewport	Simulated geometry and simulation day; no claim of a real follow-up scan
Chart and table	Item origin, unit and actual/simulation time basis; distinguish marker and line style
Interpretation	Scope identifies hypothetical context; findings refer to simulated values explicitly
Export or report	Row/claim-level origin, baseline and branch/run IDs, generation version and limitation statement
Screenshots and slides	Visible context/origin label that survives cropping where practicable; captions repeat it
Evaluation	Separate real and simulated outcomes and original-patient denominators

SAFE-07 The following wording shall appear in a synthetic workspace and generated reports: “Hypothetical simulation from a real research baseline. This is not an observed outcome or a validated prediction of this person's treatment response.” The application-wide statement is: “Research prototype. Not validated for diagnosis or treatment decisions.” Keep text visible and understandable; color alone is insufficient.

SAFE-08 Synthetic notes must be grounded in the generated structured record and labeled synthetic. Synthetic values cannot enter real-data training/evaluation pools through export or downstream joins. Any permitted use of synthetic training material must be declared, versioned and evaluated separately on independent real outcomes before generalization claims.

SAFE-09 Illustrative tissue context is not patient-derived anatomy. Hypoxia, necrosis, drug penetration, immune activity, resistance and metastasis maps require specific supporting measurements/models. P0 does not visualize them as patient facts. Do not fabricate diagnostic-looking follow-up MRI to make the presentation more convincing.

5 Clinical statement boundaries

Statement class	Permitted example	Boundary
Source description	The source record reports HER2 status as unknown.	Preserve uncertainty and exact source context
Deterministic comparison	The comparable mask-derived volume increased between these two source times.	State method, units and meaning; no causal inference
Synthetic pattern	This hypothetical branch shows shrinkage followed by regrowth.	Not evidence of this patient's future or biological resistance
General evidence	This approved publication discusses the selected research topic.	Background evidence cannot supply missing case facts
Hypothesis	This pattern may warrant further research review.	Label hypothesis and list missing evidence
Formal clinical assessment	Source-documented assessment may be displayed with its source.	New RECIST, pCR or adverse-event classification needs its actual required evidence and implemented reviewed rules

SAFE-10 Do not infer stage, receptor status, histology, treatment benefit, adverse-event causation, survival or molecular resistance from unsupported combinations of MRI, routine laboratory values and simulation patterns. A shrinking lesion does not establish pathologic complete response. A volumetric threshold alone is not a formal diameter-based response assessment. A worsening laboratory value does not establish drug toxicity causation.

SAFE-11 Exposure compatibility in a configured research scenario is not a clinical treatment recommendation. No best-treatment ranking, dose, prescription, autonomous diagnosis or patient-specific survival percentage is allowed in P0. A source quotation mentioning clinical advice may be represented as a historical documented statement, never transformed into a new recommendation by CancerOS.

SAFE-12 Model names, framework availability and structured JSON output do not establish medical suitability. A segmentation framework is not an evaluated checkpoint. Provider account access, data handling, exact model identity and capability must be verified before enabling it. Record limitations if the provider does not expose an immutable model revision.

6 Uncertainty missingness and abstention

Represent uncertainty by its type and evidence, not one invented confidence score. Record measurement uncertainty where supported; annotation variability; registration quality; simulation-parameter variation; missing/conflicting source information; and predictive uncertainty only for a separately evaluated forecasting method. A range produced by chosen simulation settings is a scenario range, not a calibrated patient prediction interval.

SAFE-13 Unknown values stay unknown. Censored results retain comparator and threshold. A missing reference interval is not a normal finding. Unknown dates remain unplaced; shifted source dates are not displayed as actual unshifted calendar dates. Incompatible time domains cannot produce authoritative intervals.

SAFE-14 Abstain when required records are absent, lesion definitions differ, source dates are unresolved, evidence conflicts or the model is outside scope. Return structured insufficient_evidence or not_comparable with reasons. A narrower qualified summary of valid available measurements is preferable to fabricated completeness. Do not treat language-model self-rated confidence as calibrated uncertainty.

SAFE-15 Do not display an earlier scan as newly acquired at a lab-only snapshot. Historical geometry has its actual source time and historical-context label. Temporal association with treatment does not establish a treatment effect. A high segmentation overlap score does not by itself establish correct lesion semantics or clinical acceptability.

7 Privacy classification and minimization

Class	Examples	Default handling
Public project material	Code without data/secrets, approved project description	Reviewed before public publication
Approved research data	Selected de-identified images and permissible metadata	Authenticated project access; source rights still apply
Restricted linkage and source content	Pseudonymous source maps, detailed notes, unreviewed metadata	Least privilege; no judge-facing exposure
Secrets	Signing credentials, provider keys, encryption/HMAC keys	Secret manager/environment; never client or logs

SAFE-16 Collect only what the selected research workflow needs. Do not solicit patient names, contact details, government IDs or actual clinical uploads from public visitors. Use approved public research sources or explicitly authorized research data. Research source availability does not automatically authorize every redistribution, commercial use, external processing or training use.

SAFE-17 Check DICOM attributes, private fields, embedded graphics and burned-in pixel identifiers, plus filenames, NIfTI headers/sidecars, spreadsheets, notes and generated previews. DICOM confidentiality profiles are useful parts of a de-identification process; they do not guarantee removal of all identifying information [R2]. Preserve scientifically necessary spatial and temporal relationships without pretending altered dates or UIDs are original values.

SAFE-18 Pseudonymization is not proof of anonymity. Linkage tables and rare combinations of source attributes can permit re-identification. Keep protected mappings separate from routine serializers; do not publish raw hashes of low-entropy identifiers. Review each public-demo bundle, including screenshot backgrounds, browser tabs and downloadable assets, for unintended disclosures.

8 External AI boundary

SAFE-19 External inference is denied by default until a versioned export policy records purpose, permitted fields/data classes, provider/account, region where applicable, retention/logging behavior, service training use, onward processing and source permissions. Unknown provider behavior means no export. De-identification alone does not override source agreements. No training or fine-tuning on protected source data without explicit applicable authorization.

The gateway builds a minimal allowlisted structured payload. P0 normally sends validated measurements, missingness, non-identifying context and approved evidence excerpts; raw DICOM, source mappings and unrestricted notes are excluded. Policy checks occur immediately before each transmission and are auditable by input hash/policy version. Avoid storing an unnecessary duplicate of the payload in ordinary logs.

SAFE-20 Notes, retrieved passages, dataset metadata and model output are untrusted content. Embedded instructions cannot grant access, request arbitrary URLs, invoke SQL, export records or execute code. The model receives no storage credentials or unrestricted tools. Validate allowlisted references and all numerical claims after generation; valid JSON is only a format check.

SAFE-21 Source text and generated prose are escaped before display. Output publication requires ownership, provenance, numeric fidelity and meaningful support, not just a plausible citation. General narrative entailment cannot be guaranteed by a simple automatic checker. Prefer bounded templates and reviewed summaries for the public demo; novel unconstrained prose remains unpublished unless its validation/review path is established.

9 Access retention and incident response

Enforce project and patient authorization in every API and artifact grant. Judge accounts are viewers. Workers have job-scoped permissions; secrets stay server-side. Use private objects, encrypted transport, protected credentials and audited sensitive operations. Short-lived grants may remain usable until expiry after withdrawal; require a proxy or provider revocation feature if immediate revocation is necessary.

SAFE-22 Retention must be approved before importing sensitive data. As initial project defaults, expire temporary exports within 24 hours and abandoned quarantined uploads within seven days unless a documented hold applies. These are operational proposals, not statutory periods. Raw data, derivatives, audit events and backups need explicit retention entries tied to source permissions and reproducibility needs. Deletion must address referenced derivatives, caches and backup expiry; access denial alone is not deletion.

SAFE-23 On suspected disclosure or scientific misrepresentation: restrict affected access or disable the inference path; preserve minimal audit evidence; identify impacted resources and recipients; correct/withdraw outputs; assess notification duties with the responsible organization; fix and retest before re-enabling. Do not delete evidence to conceal a failure. Record who made the release decision and when. No legal notification deadline is assumed in this specification.

10 Scientific reporting and change governance

Every evaluated result identifies question, outcome definition, source cohort, independent patient count, exclusions, missingness, data split, code/model/configuration and result uncertainty. Report failures and abstentions in denominators. Do not describe tuned demo cases as an unseen test set. Never count branch descendants or MRI phases as independent real patients.

SAFE-24 Freeze evaluation settings before final testing. If a test set is inspected for tuning, relabel it development and obtain a fresh independent test set where possible; otherwise disclose the limitation and make no independent validation claim. Keep a model/data card and versioned report, with publication and source-rights references.

SAFE-25 Claims in slides, narration, website and repository must match the evidence ledger: demonstrated, measured_on_named_test_set, proposed, or not_evaluated. No claim of finalist selection, organizer-provided credits/tools, clinical approval or measured accuracy without verified evidence. A saved result, rule-based fallback or recorded video must be identified accurately.

Prompt templates, rulesets, corpus updates, provider/model changes, source replacements and geometry algorithms trigger the affected regression tests. A new pipeline version never retroactively changes old published results. Cross-document rule changes are recorded explicitly rather than silently changing enum meanings or safety boundaries.

11 Release gate and evidence checklist

Release requires zero unresolved critical identity, privacy, provenance or prohibited-claim failures in the frozen release suite; all required control tests must pass. Zero detected failures is a finite-test observation, not proof of zero real-world risk. Missing evidence is not a pass. Any unsupported critical statement blocks publication even if an average metric is high.

Required evidence: source/rights ledger; patient linkage and mask review; provenance/export tests; external processing policy or disabled gateway; claim-validation tests; source/synthetic split audit; redacted-log inspection; role/object-access tests; annotated demo outputs; and an honest limitations statement. If an optional model fails its gate, disable that capability and identify the reduced scope. Do not drop an essential provenance gate to meet a presentation deadline.

12 References and related specifications

Primary project dependencies: COS-SPEC-007 architecture, COS-SPEC-008 contracts and COS-SPEC-009 UI/demo. Supporting source requirements are COS-SPEC-003 data, COS-SPEC-004 simulation and COS-SPEC-006 intelligence. COS-SPEC-011 defines the tests; COS-SPEC-012 sequences their implementation. This document resolves derived-synthetic labeling explicitly; the implementation must carry that decision into contracts and serializers.

- R1 NIST AI Risk Management Framework resources, checked 22 October 2026: https://www.nist.gov/itl/ai-risk-management-framework
- R2 DICOM PS3.15 Attribute Confidentiality Profiles, checked 22 October 2026: https://dicom.nema.org/medical/dicom/current/output/chtml/part15/chapter_E.html

These references inform governance and imaging confidentiality; they do not establish CancerOS certification or legal compliance. Project-specific retention defaults, gates and role assignments are proposed implementation rules.